

Security overview

1,432

ORGANIZATION RISK SCORE

CRITICAL

3

HIGH

22

MEDIUM

17

ASSETS

12

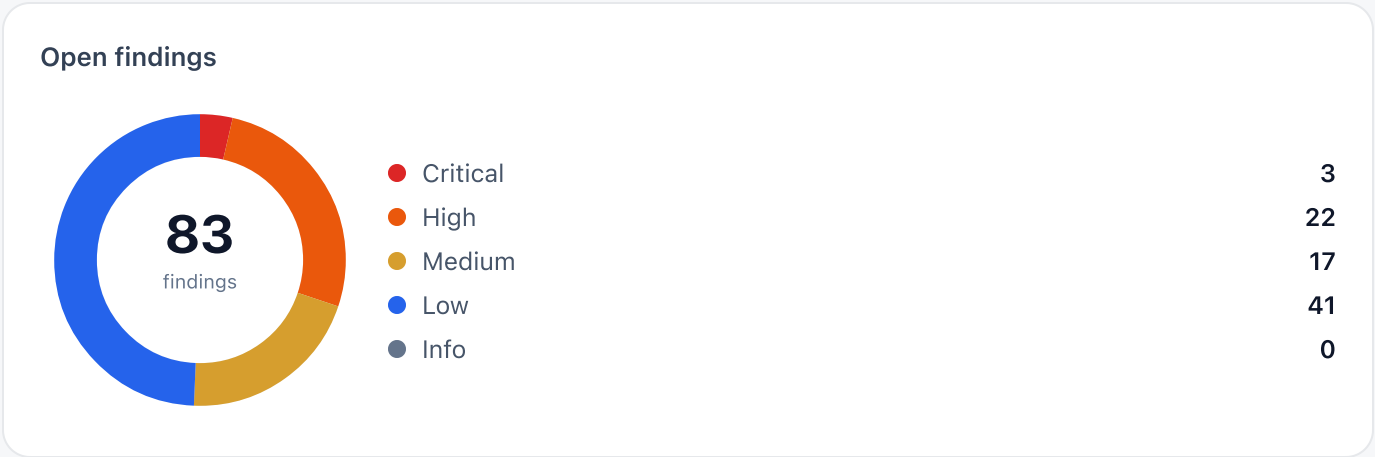
0 clean

TEAMS

1

FINDINGS

83



Most at-risk assets

ASSET	TYPE	OWNER	FINDINGS	RISK
api-internal.acme-corp.com	dns_record	unknown	16	CRITICAL D
admin-staging.payments.example.com	dns_record	unknown	8	HIGH C
grafana.example.com	dns_record	unknown	8	HIGH C
a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	api_gateway	unknown	7	HIGH C
checkout.example.com	dns_record	unknown	7	HIGH C
search-public-alb-1234567890.us-east-1.elb.amazonaws.com	load_balancer	unknown	7	HIGH C
shop.example.com	dns_record	unknown	7	HIGH C

ASSET	TYPE	OWNER	FINDINGS	RISK
a1b2c3d4e5f6.lambda-url.us-east-1.on.aws	lambda_url	unknown	6	HIGHC

New domains

Newly created hosted zones / registered domains (Route53 CreateHostedZone, RegisterDomain).

ASSET	TYPE	OWNER	FINDINGS	RISK
acme-labs.com	hosted_zone	unknown	6	HIGH C

Details

6 issue(s) found on acme-labs.com (hosted_zone, owner: unknown). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
2. Disable unused methods at the application/proxy layer.
3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
4. Define a restrictive CSP appropriate to the app.
5. Add `X-Content-Type-Options: nosniff`.
6. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from acme-labs.com
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from acme-labs.com
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from acme-labs.com
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from acme-labs.com

COLLECTED METADATA

OWNERSHIP & TAGS

Created by arn:aws:sts::111122223333:assumed-role/platform-team/terraform

Account 111122223333

Region us-east-1

Discovered via CreateHostedZone

DNS / IP

Reachable no

HTTP

Status 403

Scheme http

Dangerous methods TRACE, DELETE, PUT

HTTP RESPONSE HEADERS

content-type text/plain

content-length 90

date Wed, 01 Jul 2026 06:21:41 GMT

NETWORK

WAF / CDN none detected

Existing domains

Records added to existing zones (Route53 ChangeResourceRecordSets) — subdomains on domains you already own.

ASSET	TYPE	OWNER	FINDINGS	RISK	
api-internal.acme-corp.com	dns_record	unknown	16	CRITICAL	D
admin-staging.payments.example.com	dns_record	unknown	8	HIGH	C
grafana.example.com	dns_record	unknown	8	HIGH	C
checkout.example.com	dns_record	unknown	7	HIGH	C
shop.example.com	dns_record	unknown	7	HIGH	C
example.com	dns_record	unknown	4	MEDIUM	B

Details

16 issue(s) found on api-internal.acme-corp.com (dns_record, owner: payments-team). Highest severity: CRITICAL — Sensitive file exposed: /.env.

RECOMMENDED ACTIONS

1. Block these paths at the edge and rotate any leaked secrets.
2. Restrict via security group/NACL to known CIDRs or a bastion; bind to private subnets.
3. Disable TLS 1.0/1.1; require TLS 1.2+.
4. Restrict to VPN/SSO/allow-list; never expose admin panels publicly.
5. Disable unused methods at the application/proxy layer.
6. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
7. Renew now; ensure automated rotation is in place.
8. Disable docs in production or require authentication.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
CRITICAL	HIGH	EXP-secret-file	Sensitive file exposed: /.env	GET /.env -> 200 (content match: True)
CRITICAL	MEDIUM	NET-port-6379	Sensitive port 6379/Redis reachable from the internet	TCP 6379 open on api-internal.acme-corp.com
CRITICAL	MEDIUM	NET-port-9200	Sensitive port 9200/Elasticsearch reachable from the internet	TCP 9200 open on api-internal.acme-corp.com
HIGH	HIGH	TLS-weak-protocol	Deprecated TLS version accepted	Accepted: TLS1.0, TLS1.1
HIGH	MEDIUM	EXP-admin	Admin/management surface exposed: /actuator/env	GET /actuator/env -> 200
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: PUT, DELETE, TRACE	Allowed: PUT, DELETE, TRACE
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from https://api-internal.acme-corp.com/
MEDIUM	HIGH	TLS-expiring	TLS certificate expiring soon	
MEDIUM	HIGH	EXP-api-docs	API documentation exposed: /v3/api-docs	GET /v3/api-docs -> 200
MEDIUM	HIGH	EXP-sensitive-name	Internet-facing hostname suggests non-public service	hostname='api-internal.acme-corp.com', keywords=['internal']

SEV	CONF	CHECK	TITLE	EVIDENCE
MEDIUM	MEDIUM	NET-port-22	Sensitive port 22/SSH reachable from the internet	TCP 22 open on api-internal.acme-corp.com
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from https://api-internal.acme-corp.com/
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from https://api-internal.acme-corp.com/
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from https://api-internal.acme-corp.com/
LOW	HIGH	HDR-server-banner	Server version disclosed in banner	Server: nginx/1.18.0
LOW	LOW	NET-no-waf	No WAF/CDN detected in front of public web asset	No CloudFront/Cloudflare/AWS WAF headers seen.

COLLECTED METADATA

OWNERSHIP & TAGS

Created by arn:aws:sts::111122223333:assumed-role/payments-deploy/ci-runner

Account 111122223333

Region us-east-1

Discovered via ChangeResourceRecordSets

Tags Owner=payments-team, env=prod

DNS / IP

Resolved IPs 203.0.113.50

Reachable yes

HTTP

Status 200

Scheme https

Server nginx/1.18.0

Title Acme Internal API

Dangerous methods PUT, DELETE, TRACE

HTTP RESPONSE HEADERS

server nginx/1.18.0

x-powered-by Express

TLS CERTIFICATE

Version TLSv1.2

Issuer Let's Encrypt

Expires in (days) 8

Self-signed no

Hostname valid yes

Weak protocols TLS1.0, TLS1.1

NETWORK

Open ports 22, 443, 6379, 9200

WAF / CDN none detected

TECHNOLOGY FINGERPRINT

Detected nginx, Express

HIGH

admin-staging.payments.example.com dns_record · unknown



8 issue(s) found on admin-staging.payments.example.com (dns_record, owner: unknown). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
2. Disable unused methods at the application/proxy layer.
3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
4. Confirm this must be public; otherwise move behind VPN/private DNS.
5. Define a restrictive CSP appropriate to the app.
6. Add `X-Content-Type-Options: nosniff`.
7. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.
8. Front the asset with AWS WAF + CloudFront or equivalent.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from admin-staging.payments.example.com
MEDIUM	HIGH	EXP-sensitive-name	Internet-facing hostname suggests non-public service	hostname='admin-staging.payments.example.com', keywords=['admin', 'staging']
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from admin-staging.payments.example.com
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from admin-staging.payments.example.com
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from admin-staging.payments.example.com
LOW	LOW	NET-no-waf	No WAF/CDN detected in front of public web asset	No CloudFront/Cloudflare/AWS WAF headers seen.

COLLECTED METADATA

OWNERSHIP & TAGS

DNS / IP

Reachable

no

Created by	arn:aws:sts::111122223333:assumed-role/payments-deploy/ci-runner
Account	111122223333
Region	us-east-1
Discovered via	ChangeResourceRecordSets

HTTP

Status	403
Scheme	http
Dangerous methods	TRACE, DELETE, PUT

NETWORK

WAF / CDN	none detected
-----------	---------------

HTTP RESPONSE HEADERS

content-type	text/plain
content-length	111
date	Wed, 01 Jul 2026 06:21:41 GMT

8 issue(s) found on grafana.example.com (dns_record, owner: unknown). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
2. Disable unused methods at the application/proxy layer.
3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
4. Confirm this must be public; otherwise move behind VPN/private DNS.
5. Define a restrictive CSP appropriate to the app.
6. Add `X-Content-Type-Options: nosniff`.
7. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.
8. Front the asset with AWS WAF + CloudFront or equivalent.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from grafana.example.com
MEDIUM	HIGH	EXP-sensitive-name	Internet-facing hostname suggests non-public service	hostname='grafana.example.com', keywords=['grafana']
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from grafana.example.com
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from grafana.example.com
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from grafana.example.com
LOW	LOW	NET-no-waf	No WAF/CDN detected in front of public web asset	No CloudFront/Cloudflare/AWS WAF headers seen.

COLLECTED METADATA

OWNERSHIP & TAGS

DNS / IP

Reachable

no

Created by	arn:aws:sts::111122223333:assumed-role/web-team/ci-runner
Account	111122223333
Region	us-east-1
Discovered via	ChangeResourceRecordSets

HTTP

Status	403
Scheme	http
Dangerous methods	TRACE, DELETE, PUT

HTTP RESPONSE HEADERS

content-type	text/plain
content-length	96
date	Wed, 01 Jul 2026 06:21:41 GMT

NETWORK

WAF / CDN	none detected
-----------	---------------

7 issue(s) found on checkout.example.com (dns_record, owner: unknown). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
2. Disable unused methods at the application/proxy layer.
3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
4. Define a restrictive CSP appropriate to the app.
5. Add `X-Content-Type-Options: nosniff`.
6. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.
7. Front the asset with AWS WAF + CloudFront or equivalent.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from checkout.example.com
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from checkout.example.com
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from checkout.example.com
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from checkout.example.com
LOW	LOW	NET-no-waf	No WAF/CDN detected in front of public web asset	No CloudFront/Cloudflare/AWS WAF headers seen.

COLLECTED METADATA

OWNERSHIP & TAGS

Created by arn:aws:sts::111122223333:assumed-role/web-team/ci-runner

Account 111122223333

Region us-east-1

Discovered via ChangeResourceRecordSets

DNS / IP

Reachable no

HTTP

HTTP RESPONSE HEADERS

Status	403
Scheme	http
Dangerous methods	TRACE, DELETE, PUT

content-type	text/plain
content-length	97
date	Wed, 01 Jul 2026 06:21:41 GMT

NETWORK

WAF / CDN	none detected
-----------	---------------

7 issue(s) found on shop.example.com (dns_record, owner: unknown). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
2. Disable unused methods at the application/proxy layer.
3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
4. Define a restrictive CSP appropriate to the app.
5. Add `X-Content-Type-Options: nosniff`.
6. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.
7. Front the asset with AWS WAF + CloudFront or equivalent.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from shop.example.com
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from shop.example.com
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from shop.example.com
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from shop.example.com
LOW	LOW	NET-no-waf	No WAF/CDN detected in front of public web asset	No CloudFront/Cloudflare/AWS WAF headers seen.

COLLECTED METADATA

OWNERSHIP & TAGS

Created by arn:aws:sts::111122223333:assumed-role/web-team/ci-runner
Account 111122223333
Region us-east-1
Discovered via ChangeResourceRecordSets

DNS / IP

Reachable no

HTTP

HTTP RESPONSE HEADERS

Status	403
Scheme	http
Dangerous methods	TRACE, DELETE, PUT

content-type	text/plain
content-length	93
date	Wed, 01 Jul 2026 06:21:41 GMT

NETWORK

WAF / CDN	none detected
-----------	---------------

4 issue(s) found on example.com (dns_record, owner: unknown). Highest severity: MEDIUM — HSTS not set.

RECOMMENDED ACTIONS

1. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
2. Define a restrictive CSP appropriate to the app.
3. Add `X-Content-Type-Options: nosniff`.
4. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from https://example.com/
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from https://example.com/
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from https://example.com/
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from https://example.com/

COLLECTED METADATA

OWNERSHIP & TAGS Discovered via manual-scan	DNS / IP Resolved IPs 104.20.23.154, 172.66.147.243 Reachable yes
HTTP Status 200 Scheme https Server cloudflare Title Example Domain	HTTP RESPONSE HEADERS date Wed, 01 Jul 2026 06:23:51 GMT content-type text/html transfer-encoding chunked connection close server cloudflare last-modified Tue, 30 Jun 2026 20:56:01 GMT allow GET, HEAD accept-ranges bytes age 3515 cf-cache-status HIT cf-ray a1435308587f29b7-HYD
TLS CERTIFICATE Version TLSv1.3 Cipher TLS_AES_256_GCM_SHA384 Issuer SSL Corporation	NETWORK WAF / CDN Cloudflare (CDN/WAF)

Subject CN	example.com
Expires in (days)	59
SANs	example.com, *.example.com
Self-signed	no
Hostname valid	yes

Endpoints & services

Load balancers, API gateways, CloudFront, Lambda URLs, EC2, RDS, S3 and other internet-facing resources.

ASSET	TYPE	OWNER	FINDINGS	RISK
a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	api_gateway	unknown	7	HIGH C
search-public-alb-1234567890.us-east-1.elb.amazonaws.com	load_balancer	unknown	7	HIGH C
a1b2c3d4e5f6.lambda-url.us-east-1.on.aws	lambda_url	unknown	6	HIGH C
ec2-203-0-113-42.us-west-2.compute.amazonaws.com	ec2_instance	unknown	6	HIGH C
acme-analytics-exports.s3.amazonaws.com	s3_bucket	unknown	1	HIGH C

Details

7 issue(s) found on a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com (api_gateway, owner: unknown). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

- 1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
- 2. Disable unused methods at the application/proxy layer.
- 3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
- 4. Define a restrictive CSP appropriate to the app.
- 5. Add `X-Content-Type-Options: nosniff`.
- 6. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.
- 7. Front the asset with AWS WAF + CloudFront or equivalent.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com
LOW	LOW	NET-no-waf	No WAF/CDN detected in front of public web asset	No CloudFront/Cloudflare/AWS WAF headers seen.

COLLECTED METADATA

OWNERSHIP & TAGS		DNS / IP	
Created by	arn:aws:sts::111122223333:assumed-role/mobile-team/deployer	Reachable	no
Account	111122223333		
Region	eu-west-1		
Discovered via	CreateRestApi		

HTTP

Status	403
Scheme	http
Dangerous methods	TRACE, DELETE, PUT

HTTP RESPONSE HEADERS

content-type	text/plain
content-length	123
date	Wed, 01 Jul 2026 06:21:41 GMT

NETWORK

WAF / CDN	none detected
-----------	---------------

HIGH

search-public-alb-1234567890.us-east-1.elb.amazonaws.com

load_balancer · unknown

7 issue(s) found on search-public-alb-1234567890.us-east-1.elb.amazonaws.com (load_balancer, owner: unknown). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

- 1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
- 2. Disable unused methods at the application/proxy layer.
- 3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
- 4. Define a restrictive CSP appropriate to the app.
- 5. Add `X-Content-Type-Options: nosniff`.
- 6. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.
- 7. Front the asset with AWS WAF + CloudFront or equivalent.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from search-public-alb-1234567890.us-east-1.elb.amazonaws.com
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from search-public-alb-1234567890.us-east-1.elb.amazonaws.com
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from search-public-alb-1234567890.us-east-1.elb.amazonaws.com
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from search-public-alb-1234567890.us-east-1.elb.amazonaws.com
LOW	LOW	NET-no-waf	No WAF/CDN detected in front of public web asset	No CloudFront/Cloudflare/AWS WAF headers seen.

COLLECTED METADATA

OWNERSHIP & TAGS		DNS / IP	
Created by	arn:aws:sts::111122223333:assumed-role/search-team/terraform	Reachable	no
Account	111122223333		
Region	us-east-1		

Discovered via CreateLoadBalancer

HTTP

Status 403
Scheme http
Dangerous methods TRACE, DELETE, PUT

HTTP RESPONSE HEADERS

content-type text/plain
content-length 133
date Wed, 01 Jul 2026 06:21:41 GMT

NETWORK

WAF / CDN none detected

HIGH

a1b2c3d4e5f6.lambda-url.us-east-1.on.aws

lambda_url · unknown



6 issue(s) found on a1b2c3d4e5f6.lambda-url.us-east-1.on.aws (lambda_url, owner: unknown). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
2. Disable unused methods at the application/proxy layer.
3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
4. Define a restrictive CSP appropriate to the app.
5. Add `X-Content-Type-Options: nosniff`.
6. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from a1b2c3d4e5f6.lambda-url.us-east-1.on.aws
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from a1b2c3d4e5f6.lambda-url.us-east-1.on.aws
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from a1b2c3d4e5f6.lambda-url.us-east-1.on.aws
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from a1b2c3d4e5f6.lambda-url.us-east-1.on.aws

COLLECTED METADATA

OWNERSHIP & TAGS

Created by arn:aws:sts::111122223333:assumed-role/billing-team/deployer

Account 111122223333

Region us-east-1

Discovered via CreateFunctionUrlConfig

DNS / IP

Reachable no

HTTP

Status 403

Scheme http

HTTP RESPONSE HEADERS

content-type text/plain

content-length 117

Dangerous methods TRACE, DELETE, PUT

date

Wed, 01 Jul 2026 06:21:41 GMT

NETWORK

WAF / CDN none detected

HIGH

ec2-203-0-113-42.us-west-2.compute.amazonaws.com

ec2_instance ·
unknown

6 issue(s) found on ec2-203-0-113-42.us-west-2.compute.amazonaws.com (ec2_instance, owner: data-platform). Highest severity: HIGH — Service served over plaintext HTTP only.

RECOMMENDED ACTIONS

1. Terminate TLS (ACM on the ALB) and redirect HTTP->HTTPS.
2. Disable unused methods at the application/proxy layer.
3. Add `Strict-Transport-Security: max-age=31536000; includeSubDomains`.
4. Define a restrictive CSP appropriate to the app.
5. Add `X-Content-Type-Options: nosniff`.
6. Add `X-Frame-Options: DENY` or CSP `frame-ancestors 'none'`.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	MEDIUM	TLS-missing	Service served over plaintext HTTP only	http reachable, https failed: [Errno 8] nodename nor servname provided, or not known
HIGH	MEDIUM	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT	Allowed: TRACE, DELETE, PUT
MEDIUM	HIGH	HDR-strict-transport-security	HSTS not set	Response from ec2-203-0-113-42.us-west-2.compute.amazonaws.com
LOW	HIGH	HDR-content-security-policy	Content-Security-Policy not set	Response from ec2-203-0-113-42.us-west-2.compute.amazonaws.com
LOW	HIGH	HDR-x-content-type-options	X-Content-Type-Options not set	Response from ec2-203-0-113-42.us-west-2.compute.amazonaws.com
LOW	HIGH	HDR-x-frame-options	Clickjacking protection missing	Response from ec2-203-0-113-42.us-west-2.compute.amazonaws.com

COLLECTED METADATA

OWNERSHIP & TAGS

Created by arn:aws:iam::111122223333:user/intern-dev
Account 111122223333
Region us-west-2
Discovered via RunInstances
Tags Owner=data-platform, env=dev

DNS / IP

Reachable no

HTTP

Status 403

HTTP RESPONSE HEADERS

content-type text/plain

Scheme http
Dangerous methods TRACE, DELETE, PUT

content-length 125
date Wed, 01 Jul 2026 06:21:41 GMT

NETWORK

WAF / CDN none detected

HIGH **acme-analytics-exports.s3.amazonaws.com** s3_bucket · unknown ▼

1 issue(s) found on acme-analytics-exports.s3.amazonaws.com (s3_bucket, owner: unknown). Highest severity: HIGH — Bucket made public by the triggering event (ACL grant): acme-analytics-exports.

RECOMMENDED ACTIONS

1. Revert the public grant and enable Block Public Access.

DETERMINISTIC FINDINGS

SEV	CONF	CHECK	TITLE	EVIDENCE
HIGH	HIGH	S3-event-public-grant	Bucket made public by the triggering event (ACL grant): acme-analytics-exports	event=PutBucketAcl

COLLECTED METADATA

OWNERSHIP & TAGS

Created by arn:aws:sts::111122223333:assumed-role/analytics-team/etl-runner
Account 111122223333
Region us-east-1
Discovered via PutBucketAcl

DNS / IP

Reachable no

S3 PUBLIC ACCESS

Bucket acme-analytics-exports
Publicly listable no
Probe method http

Findings

Every deterministic finding across all assets, worst first. Alerts fire on severity AND confidence.

SEVERITY	CONFIDENCE	ASSET	CHECK	TITLE
CRITICAL	HIGH	api-internal.acme-corp.com	EXP-secret-file	Sensitive file exposed: /.env
CRITICAL	MEDIUM	api-internal.acme-corp.com	NET-port-6379	Sensitive port 6379/Redis reachable from the internet
CRITICAL	MEDIUM	api-internal.acme-corp.com	NET-port-9200	Sensitive port 9200/Elasticsearch reachable from the internet
HIGH	HIGH	api-internal.acme-corp.com	TLS-weak-protocol	Deprecated TLS version accepted
HIGH	MEDIUM	api-internal.acme-corp.com	EXP-admin	Admin/management surface exposed: /actuator/env
HIGH	MEDIUM	api-internal.acme-corp.com	HTTP-methods	Dangerous HTTP methods enabled: PUT, DELETE, TRACE
MEDIUM	HIGH	api-internal.acme-corp.com	HDR-strict-transport-security	HSTS not set
MEDIUM	HIGH	api-internal.acme-corp.com	TLS-expiring	TLS certificate expiring soon
MEDIUM	HIGH	api-internal.acme-corp.com	EXP-api-docs	API documentation exposed: /v3/api-docs
MEDIUM	HIGH	api-internal.acme-corp.com	EXP-sensitive-name	Internet-facing hostname suggests non-public service
MEDIUM	MEDIUM	api-internal.acme-corp.com	NET-port-22	Sensitive port 22/SSH reachable from the internet
LOW	HIGH	api-internal.acme-corp.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	api-internal.acme-corp.com	HDR-x-content-type-options	X-Content-Type-Options not set

SEVERITY	CONFIDENCE	ASSET	CHECK	TITLE
LOW	HIGH	api-internal.acme-corp.com	HDR-x-frame-options	Clickjacking protection missing
LOW	HIGH	api-internal.acme-corp.com	HDR-server-banner	Server version disclosed in banner
LOW	LOW	api-internal.acme-corp.com	NET-no-waf	No WAF/CDN detected in front of public web asset
HIGH	MEDIUM	admin-staging.payments.example.com	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	admin-staging.payments.example.com	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	admin-staging.payments.example.com	HDR-strict-transport-security	HSTS not set
MEDIUM	HIGH	admin-staging.payments.example.com	EXP-sensitive-name	Internet-facing hostname suggests non-public service
LOW	HIGH	admin-staging.payments.example.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	admin-staging.payments.example.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	admin-staging.payments.example.com	HDR-x-frame-options	Clickjacking protection missing
LOW	LOW	admin-staging.payments.example.com	NET-no-waf	No WAF/CDN detected in front of public web asset
HIGH	MEDIUM	grafana.example.com	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	grafana.example.com	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	grafana.example.com	HDR-strict-transport-security	HSTS not set
MEDIUM	HIGH	grafana.example.com	EXP-sensitive-name	Internet-facing hostname suggests non-public service

SEVERITY	CONFIDENCE	ASSET	CHECK	TITLE
LOW	HIGH	grafana.example.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	grafana.example.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	grafana.example.com	HDR-x-frame-options	Clickjacking protection missing
LOW	LOW	grafana.example.com	NET-no-waf	No WAF/CDN detected in front of public web asset
HIGH	MEDIUM	a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	HDR-strict-transport-security	HSTS not set
LOW	HIGH	a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	HDR-x-frame-options	Clickjacking protection missing
LOW	LOW	a1b2c3d4e5.execute-api.eu-west-1.amazonaws.com	NET-no-waf	No WAF/CDN detected in front of public web asset
HIGH	MEDIUM	checkout.example.com	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	checkout.example.com	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	checkout.example.com	HDR-strict-transport-security	HSTS not set

SEVERITY	CONFIDENCE	ASSET	CHECK	TITLE
LOW	HIGH	checkout.example.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	checkout.example.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	checkout.example.com	HDR-x-frame-options	Clickjacking protection missing
LOW	LOW	checkout.example.com	NET-no-waf	No WAF/CDN detected in front of public web asset
HIGH	MEDIUM	search-public-alb-1234567890.us-east-1.elb.amazonaws.com	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	search-public-alb-1234567890.us-east-1.elb.amazonaws.com	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	search-public-alb-1234567890.us-east-1.elb.amazonaws.com	HDR-strict-transport-security	HSTS not set
LOW	HIGH	search-public-alb-1234567890.us-east-1.elb.amazonaws.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	search-public-alb-1234567890.us-east-1.elb.amazonaws.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	search-public-alb-1234567890.us-east-1.elb.amazonaws.com	HDR-x-frame-options	Clickjacking protection missing
LOW	LOW	search-public-alb-1234567890.us-east-1.elb.amazonaws.com	NET-no-waf	No WAF/CDN detected in front of public web asset
HIGH	MEDIUM	shop.example.com	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	shop.example.com	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	shop.example.com	HDR-strict-transport-security	HSTS not set

SEVERITY	CONFIDENCE	ASSET	CHECK	TITLE
LOW	HIGH	shop.example.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	shop.example.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	shop.example.com	HDR-x-frame-options	Clickjacking protection missing
LOW	LOW	shop.example.com	NET-no-waf	No WAF/CDN detected in front of public web asset
HIGH	MEDIUM	a1b2c3d4e5f6.lambda-url.us-east-1.on.aws	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	a1b2c3d4e5f6.lambda-url.us-east-1.on.aws	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	a1b2c3d4e5f6.lambda-url.us-east-1.on.aws	HDR-strict-transport-security	HSTS not set
LOW	HIGH	a1b2c3d4e5f6.lambda-url.us-east-1.on.aws	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	a1b2c3d4e5f6.lambda-url.us-east-1.on.aws	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	a1b2c3d4e5f6.lambda-url.us-east-1.on.aws	HDR-x-frame-options	Clickjacking protection missing
HIGH	MEDIUM	acme-labs.com	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	acme-labs.com	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	acme-labs.com	HDR-strict-transport-security	HSTS not set
LOW	HIGH	acme-labs.com	HDR-content-security-policy	Content-Security-Policy not set

SEVERITY	CONFIDENCE	ASSET	CHECK	TITLE
LOW	HIGH	acme-labs.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	acme-labs.com	HDR-x-frame-options	Clickjacking protection missing
HIGH	MEDIUM	ec2-203-0-113-42.us-west-2.compute.amazonaws.com	TLS-missing	Service served over plaintext HTTP only
HIGH	MEDIUM	ec2-203-0-113-42.us-west-2.compute.amazonaws.com	HTTP-methods	Dangerous HTTP methods enabled: TRACE, DELETE, PUT
MEDIUM	HIGH	ec2-203-0-113-42.us-west-2.compute.amazonaws.com	HDR-strict-transport-security	HSTS not set
LOW	HIGH	ec2-203-0-113-42.us-west-2.compute.amazonaws.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	ec2-203-0-113-42.us-west-2.compute.amazonaws.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	ec2-203-0-113-42.us-west-2.compute.amazonaws.com	HDR-x-frame-options	Clickjacking protection missing
HIGH	HIGH	acme-analytics-exports.s3.amazonaws.com	S3-event-public-grant	Bucket made public by the triggering event (ACL grant): acme-analytics-exports
MEDIUM	HIGH	example.com	HDR-strict-transport-security	HSTS not set
LOW	HIGH	example.com	HDR-content-security-policy	Content-Security-Policy not set
LOW	HIGH	example.com	HDR-x-content-type-options	X-Content-Type-Options not set
LOW	HIGH	example.com	HDR-x-frame-options	Clickjacking protection missing

Discovery sources

How each asset was discovered — the CloudTrail event and the normalised type. This is the event-driven discovery layer in action.

By asset type

dns_record	6
api_gateway	1
load_balancer	1
lambda_url	1
hosted_zone	1
ec2_instance	1
s3_bucket	1

By discovery event

ChangeResourceRecordSets	5
CreateRestApi	1
CreateLoadBalancer	1
CreateFunctionUrlConfig	1
CreateHostedZone	1
RunInstances	1
PutBucketAcl	1
manual-scan	1